

So in this project we are going to learn what is the

- 1) Burp suit tool
- 2) Features of the burp suit
- 3) The dashboard
- 4) Navigation
- 5) Option
- 6) Introduction to burp proxy
- 7) Burp suit browser
- 8) Scoping and targeting
- 9) Example attack

1) **What Is The Burp Suit :**

Burp suit is the java based tool that is used to do manual penetration testing.

Burp suit is API based tool.

It allows pentester to capture HTTP/HTTPS traffic between web browser and server and manipulate the traffic.

2) **Features of the burp suit**

As discussed above burp suit allows pentester to capture traffic and manipulate it, but it has different features available inside it to do the process lets discuss one by one.

- Proxy: The Burp Proxy is the most renowned aspect of Burp Suite, it allows burp suit to intersect the request and response between web application and server.
- Repeater: Another great feature is repeater which allows capturing, modifying, resending the same request multiple time.
- Intruder: [Intruder](#) allows for spraying endpoints with requests. It is useful for brute force attack and fuzzing.
- Decoder: it is the most important feature in burp suit which helps to encode decode data in various forms just like cyberchef.
- Comparer: as name suggest comparer enables comparing between two data either in binary of ascii.
- Sequencer: is feature that used to understand randomness of token or session ids.

3) The dashboard:

In burp suit community edition options are limited. But from tryhackme walkthrough I have added the options that prompted when you launch burp suit professional.

- Tasks: Task menu will allow you to define background task that burp suit will perform while you use the burp suit.
- Event log: it will provide the information about actions performed by burp suit, for ex starting the proxy
- Issue activity: this is the burp suit professional window which shows the vulnerability scanned by automated scanner. These are ranked by severity and filtered based on the certainty.
- Advisory: The advisory section provides more information about identified vulnerabilities. Which also include reference and remediations. This information is exported in report to certain analysis.

Below I have added four screenshots of each section go through it .

The image displays four screenshots of the Burp Suite Professional interface, arranged in a 2x2 grid. The top-left screenshot shows the 'Tasks' panel with a 'New live task' button and a task titled '1. Live passive crawl from Proxy (all traffic)'. The top-right screenshot shows the 'Issue activity' panel with a table of vulnerabilities. The bottom-left screenshot shows the 'Event log' panel with a table of events. The bottom-right screenshot shows the 'Advisory' panel, which is currently empty.

Issue activity [Pro version only]

Issue type	Host	URL
Suspicious input transformation (reflected)	http://insecure-bank.com	/url-shorten
SMTP header injection	http://insecure-website.c...	/contact-us
Serialized object in HTTP message	http://insecure-bank.com	/blog
Cross-site scripting (DOM-based)	https://insecure-bank.com	/
XML external entity injection	https://vulnerable-website...	/product/stock
External service interaction (HTTP)	https://insecure-website...	/product
Web cache poisoning	http://insecure-bank.com	/contact-us

Event log

Time	Type	Source	Message
01:51:02 8 Sep 2021	Info	Proxy	Proxy service started c

Advisory

Memorv: 94.7MB | Disk: 32KB

- 4) **Navigation:** In burp suit the navigation is mainly done by navigation bar available at top.by using various options in this bar we can switch to different types of sections and uses.

These are also known as the sub tabs from where we can switch to different types of modules.

Take a look at screenshot I have added below for better understanding.



Burp suit also provide keyword shortcuts for switching over modules I have added some essential keyword shortcuts.

Ctrl + Shift + D	Dashboard
Ctrl + Shift + T	Target tab
Ctrl + Shift + P	Proxy tab
Ctrl + Shift + I	Intruder tab
Ctrl + Shift + R	Repeater tab

BURP SUIT THE BASICS

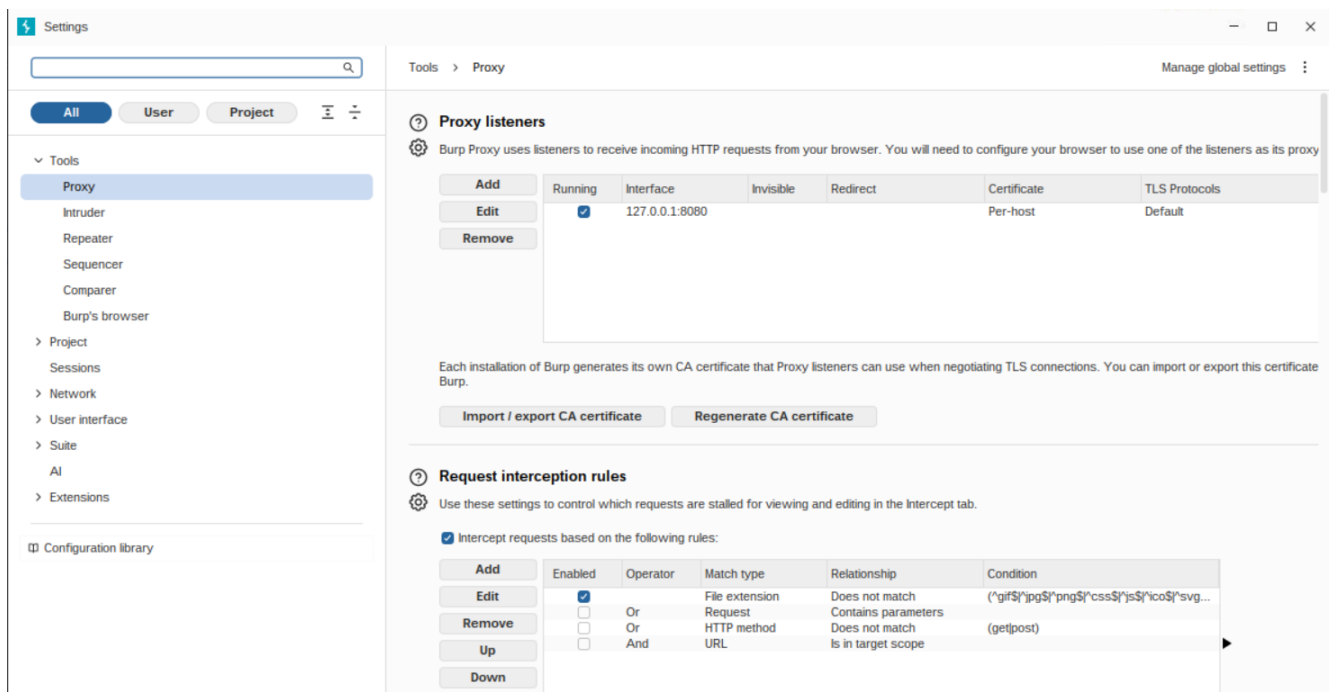
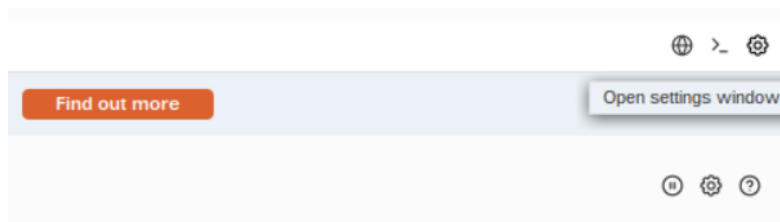
5)**Options** : Before going deep into burp suit let's explore some of the option available which are very essentials

Burp suit has two setting

Global setting also known as user setting : This setting affect entire burp suit installation and applied every time you start application.

Project setting: This setting applied on only current setting

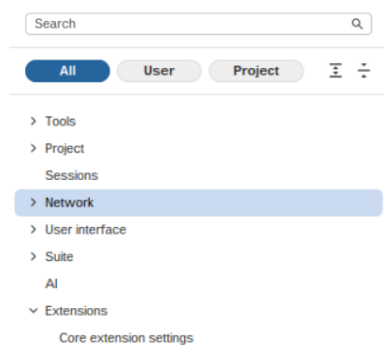
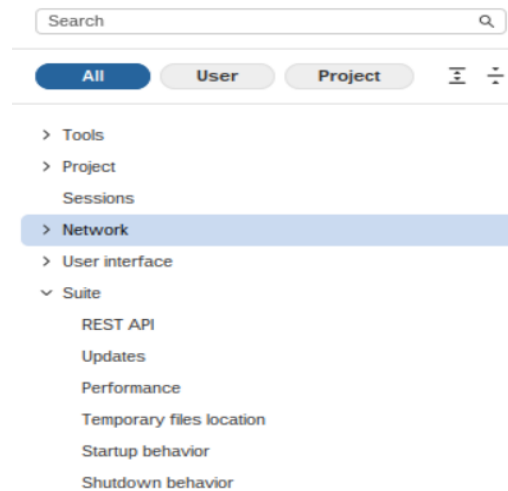
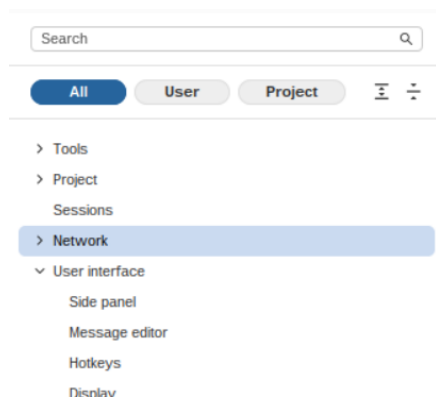
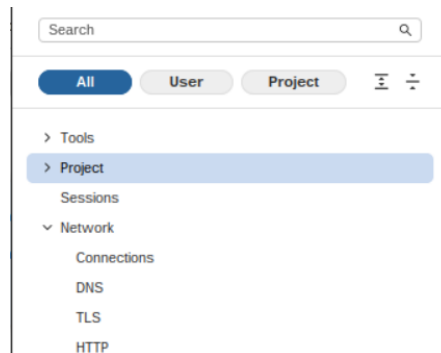
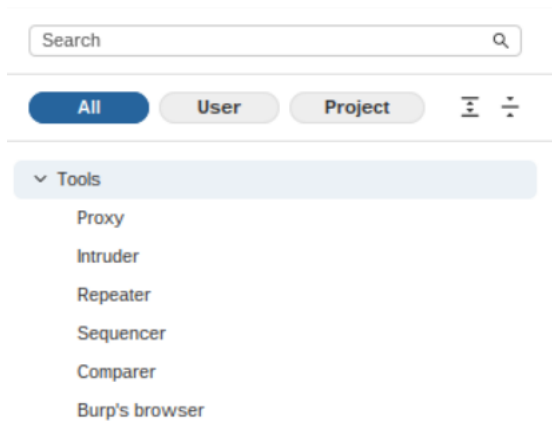
To access this setting click on setting icon on top right corner. For further info take a look at screenshot below.



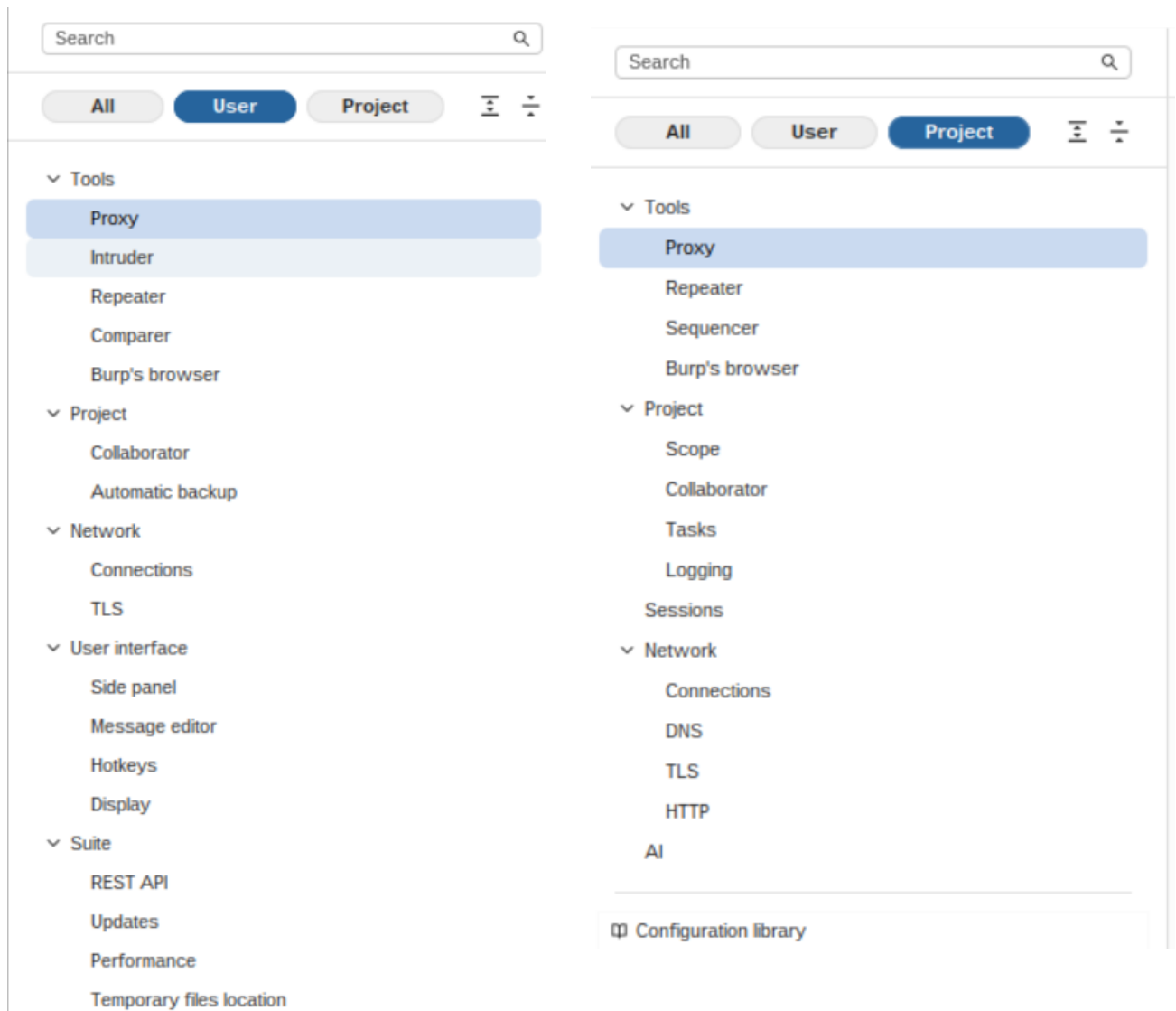
BURP SUIT THE BASICS

In the second screenshot above you can see search bar, types of setting and various categories of setting available.

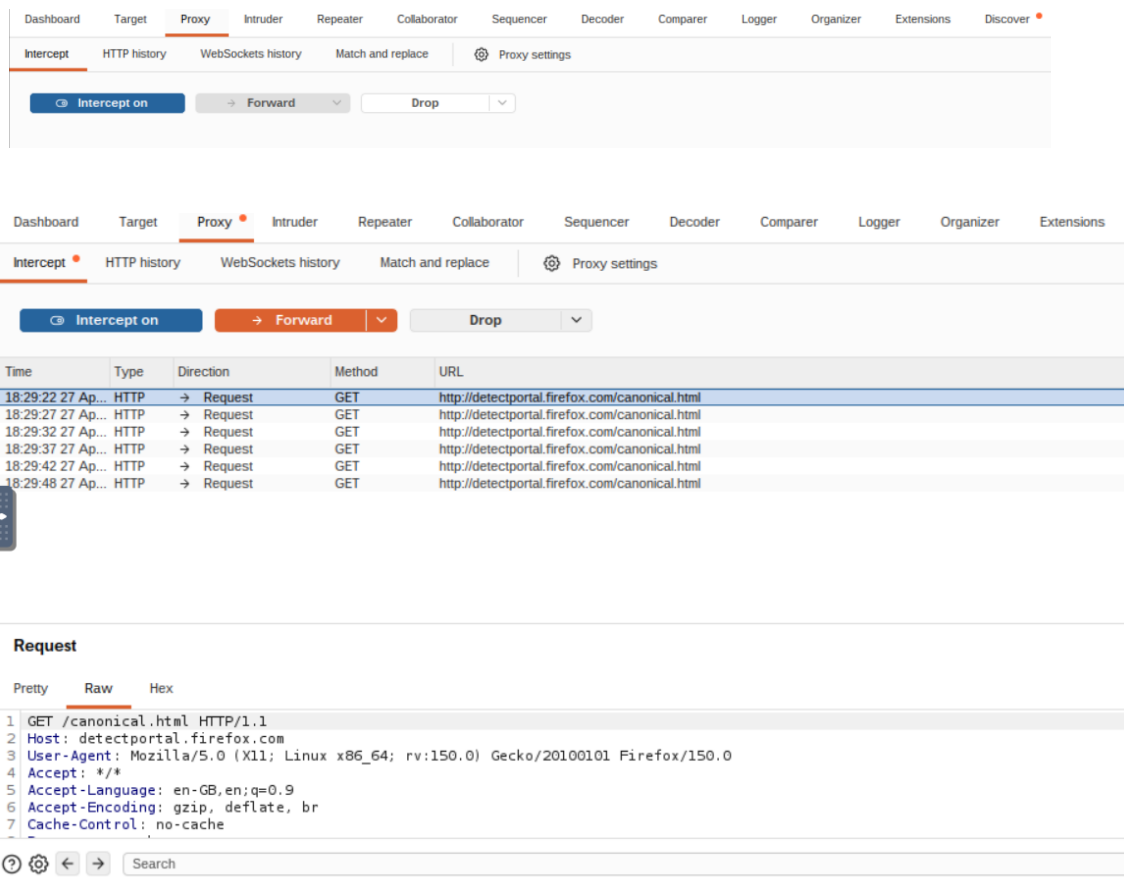
Let's explore every tab see the screenshots below:-I have expanded every tab to see the subcategories in there.



BURP SUIT THE BASICS



- 6) **Introduction to burp proxy**: - The burp proxy is the crucial tool in burp suit that allows the tool to capture and manipulate the request according to need. When the requests are made from burp proxy that are intercepted and held back from reaching the target server. The request appears in proxy tab and allowing for further action such as allowing, dropping, or forwarding to another burp modules.



As you can see above I caught traffic through proxy made in Firefox browser.

The ability to intercept request gives complete power to tester to test the request in various ways.

Even if you have stopped capturing the traffic in proxy burp suit can still capture traffic.so later you can analyse it.

Some websites use WebSocket technique which also captured by burp suit

These captured requests are viewed in http history and WebSocket history.as shown below in screenshot.

BURP SUIT THE BASICS

Intercept HTTP history WebSockets history Match and replace Proxy settings															
Filter settings: Hiding CSS and image content; hiding specific extensions											Pro version only				
Host	Method	URL	Params	Edited	Status code	Length	MIME type	Extension	Title	Notes	TLS	IP	Time	Listener port	Start response
http://detectportal.firefox.com	GET	/canonical.html			200	298	HTML	html				34.107.221.82	18:28:06.27 ...	8080	5
http://detectportal.firefox.com	GET	/canonical.html			200	298	HTML	html				34.107.221.82	18:28:11.27 ...	8080	4
http://detectportal.firefox.com	GET	/canonical.html			200	298	HTML	html				34.107.221.82	18:28:16.27 ...	8080	5
http://detectportal.firefox.com	GET	/success.txt?ipv4	✓		200	216	text	txt				34.107.221.82	18:28:20.27 ...	8080	5
http://detectportal.firefox.com	GET	/success.txt?ipv6	✓		200	216	text	txt				34.107.221.82	18:28:20.27 ...	8080	4
http://detectportal.firefox.com	GET	/canonical.html			200	298	HTML	html				34.107.221.82	18:28:26.27 ...	8080	4
http://detectportal.firefox.com	GET	/success.txt?ipv4	✓		200	216	text	txt				34.107.221.82	18:28:31.27 ...	8080	7
http://detectportal.firefox.com	GET	/success.txt?ipv6	✓		200	216	text	txt				34.107.221.82	18:28:31.27 ...	8080	3
http://detectportal.firefox.com	GET	/canonical.html			200	298	HTML	html				34.107.221.82	18:28:45.27 ...	8080	5
http://detectportal.firefox.com	GET	/canonical.html			200	298	HTML	html				34.107.221.82	18:28:46.27 ...	8080	5
http://detectportal.firefox.com	GET	/canonical.html			200	298	HTML	html				34.107.221.82	18:28:47.27 ...	8080	4
http://detectportal.firefox.com	GET	/canonical.html			200	298	HTML	html				34.107.221.82	18:28:47.27 ...	8080	6
http://detectportal.firefox.com	GET	/canonical.html			200	298	HTML	html				34.107.221.82	18:28:47.27 ...	8080	4
http://detectportal.firefox.com	GET	/canonical.html			200	298	HTML	html				34.107.221.82	18:28:48.27 ...	8080	4
http://detectportal.firefox.com	GET	/success.txt?ipv4	✓		200	216	text	txt				34.107.221.82	18:28:48.27 ...	8080	3

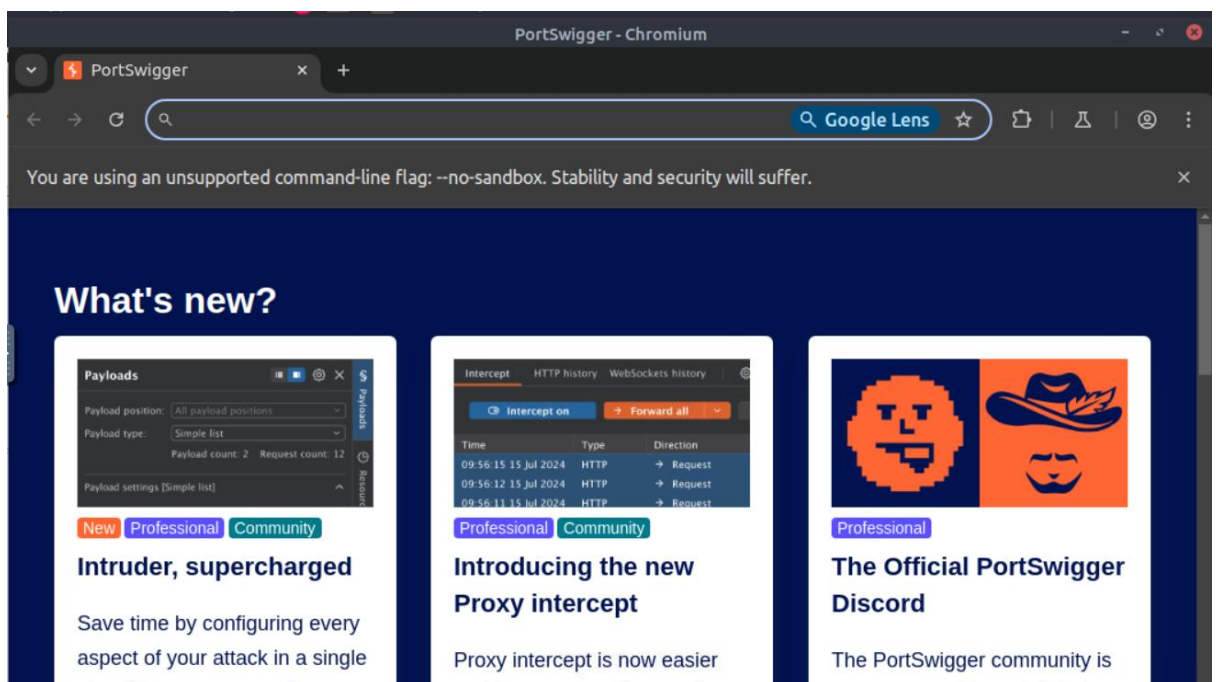
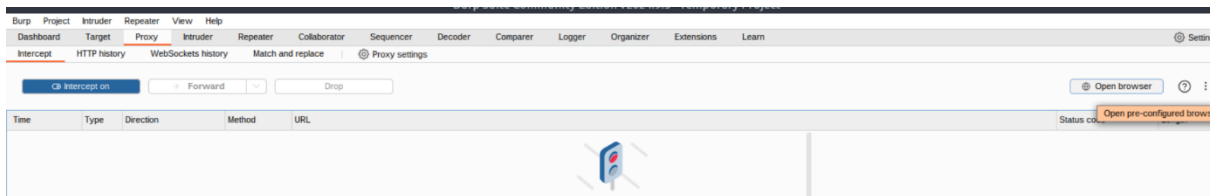
BURP SUIT THE BASICS

7) **Burp suit browser:**

If you feel complex to install foxy proxy to connect burp suit, burp suit has solution for it.

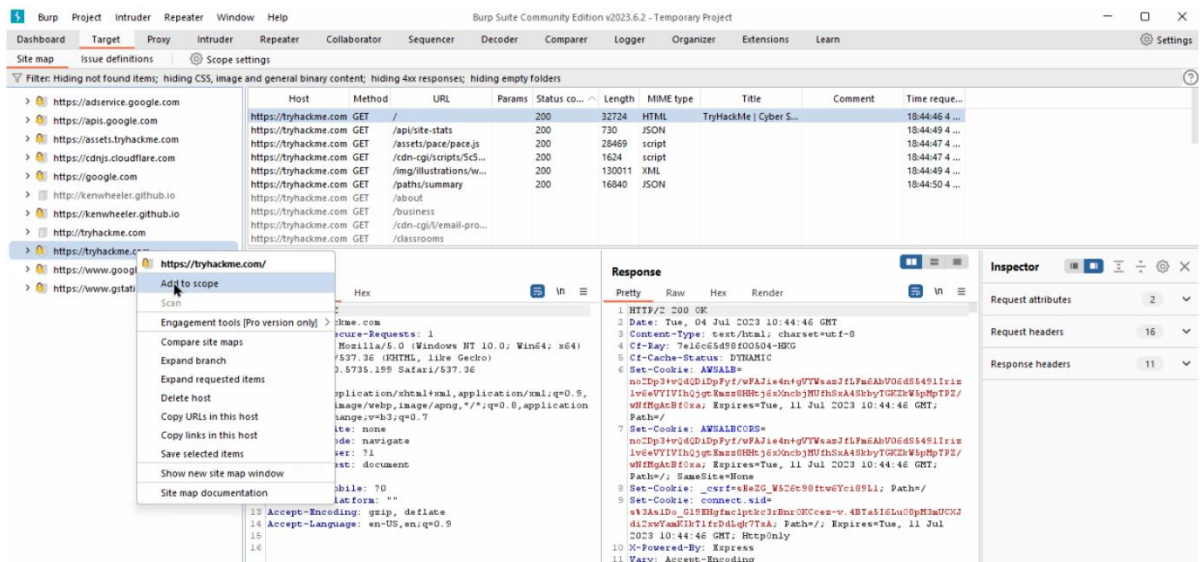
It provides a built-in chromium browser in which we don't need to set any foxy proxy.

Take a look at screenshot below.



8) Scoping and Targeting:

When you are capturing all the traffic but you cant find the right one you want and also capturing all the traffic can be overwhelming here Scoping comes in frame where you can add your target to scope and only capture the related traffic to it. See the screen shot below I have added tryhackme website to scope in burp suit.

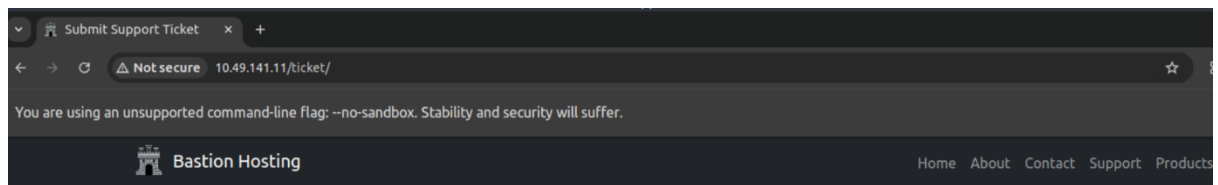


9) Example attack:

Here we will see the basic example of manipulating the request made through the browser and intercepted and edited by burp suit.

I have entered the website address given in tryhackme room

The script provided there is not accepted by input field. This means it is client side filter that not allowing any special character's in input field I shown input field below.





Support

Now I tired as per instruction legitimate email address pentester@gmail.com and query as “test attack” and press entre.

I captured this request in burp suit and at the field of email address I entered the script “<script>alert("Succ3ssful XSS")</script>”

Dashboard
Target
Proxy
Intruder
Repeater
Collaborator
Sequencer
Decoder
Comparer
Logger
Organizer
Extensions
Learn

Intercept
HTTP history
WebSockets history
Match and replace
Proxy settings

Intercept on
Forward
Drop
Request to http://10.49.141.11

Time	Type	Direction	Method	URL
17:19:56.28	Ap...	HTTP	→ Request	GET http://10.49.141.11/5yR2GLCoGoj2ZK
17:21:57.28	Ap...	HTTP	→ Request	POST http://10.49.141.11/ticket/

Request
Pretty
Raw
Hex

```

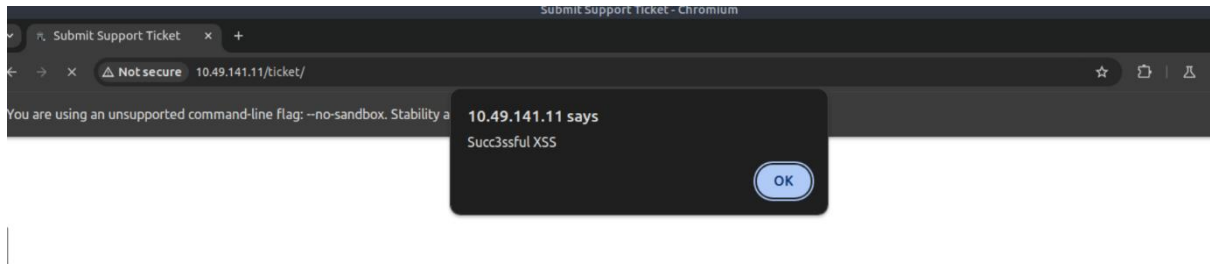
1 POST /ticket/ HTTP/1.1
2 Host: 10.49.141.11
3 Content-Length: 49
4 Cache-Control: max-age=0
5 Accept-Language: en-GB,en;q=0.9
6 Origin: http://10.49.141.11
7 Content-Type: application/x-www-form-urlencoded
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/130.0.6723.70 Safari/537.36
10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
11 Referer: http://10.49.141.11/ticket/
12 Accept-Encoding: gzip, deflate, br
13 Connection: keep-alive
14 email=<script>alert("Succ3ssful XSS")</script>&content=test+attack
15

```

Inspector
Request attribut
Request query
Request body p
Request cookie
Request header

BURP SUIT THE BASICS

After pressing forward button the script run and showed the screenshot of “xss attack successful”.



Conclusion:

- By Completing Above Modules, I Learned The
- Basic Interface Of Burp Suit
- What Are The Different Functions Of Burp Suit
- How To Capture And Edit The Request
- And All The Essential Concepts To Further Learning,

Thank you.